SIMATS ENGINEERING

ASSESSMENT TOOL 2

COURSE NAME: Ethical Hacking

COURSE CODE: ITA14

COURSE OUTCOME COVERED

CO2: Execute footprinting in social engineering such as DNS analysis, competitive intelligence gathering, and attack simulations to collect relevant information for identifying potential security risks.

Assessment Tool Weightage: 30%

Duration: 90 min Total Marks: 50

Code of Conduct:

I **SHAIK THAHEER (192425347)** (Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment.

I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of the student: **SHAIK THAHEER**

Social Engineering Simulation

Questions

1. As a Security Analyst, perform an OSINT-based email enumeration assessment on the target domain tesla.com using the Harvester in Kali Linux. Collect publicly available email addresses, subdomains, hosts, and IP addresses associated with the organization. Categorize the discovered email addresses into likely roles such as Support, Sales, Human Resources, Administration, and Technical Teams. Analyze how the gathered information could assist an attacker during the reconnaissance phase and explain how it could be used for spear-phishing, credential harvesting, and impersonation attacks. Finally, recommend at least five countermeasures to reduce information leakage and social engineering risks, and submit a report with screenshots, commands executed, findings, risk analysis, and recommendations. (20 Marks)

2. As a cybersecurity awareness consultant, you are required to conduct a phishing awareness simulation using GoPhish and dummy employee accounts provided in the lab. Create an email template, launch a campaign, monitor user interactions, and generate a report showing delivery rate, email open rate, and click rate. Based on the results, provide recommendations to improve user awareness against phishing attacks.(20 Mark).

3. Using Nmap Aggressive Scan (-A) on scanme.nmap.org, gather detailed information about the target including operating system details, open ports, and service versions. Assume you are an attacker and describe how the collected information could be leveraged to conduct a social engineering attack against the IT support team. Prepare a report explaining the attack methodology and defensive recommendations. (10 Marks)

Question 1: OSINT-Based Email Enumeration Using theHarvester (20 Marks)

1. Aim

To perform an Open-Source Intelligence (OSINT) assessment of tesla.com using theHarvester in Kali Linux to identify publicly available email addresses, subdomains, hosts, and IP addresses, analyze security risks, and recommend countermeasures.

2. Tools Required

- Kali Linux
- theHarvester
- Terminal
- Public search engines and OSINT data sources
- Screenshot tool for documenting the results

3. Introduction

OSINT is the process of collecting and analyzing information from publicly available sources. Security analysts use OSINT to understand an organization's external exposure and identify information that could be misused by attackers.

theHarvester is an OSINT tool that gathers information such as email addresses, subdomains, hostnames, and IP addresses from supported public sources.

The assessment of tesla.com should be conducted for educational and defensive purposes. Publicly visible information does not automatically mean a system is vulnerable.

4. Commands Executed

Step 1: Open Kali Linux terminal

Update the package list:

sudo apt update

Install theHarvester if it is not already installed:

sudo apt install theharvester

Step 2: Check the tool

theHarvester -h

This displays the available options and supported data sources.

Step 3: Perform an OSINT search

Use a supported public data source. For example:

theHarvester -d tesla.com -b duckduckgo

The exact available sources depend on the installed version. If that source is unsupported, check the help output and select an available source.

Step 4: Collect a limited set of results

theHarvester -d tesla.com -l 100 -b duckduckgo

Here:

- -d tesla.com specifies the target domain.
- -l 100 limits the number of results requested.
- -b duckduckgo selects the data source, if supported by the installed version.

Step 5: Save the results

Check the version's help output for supported export options. If JSON output is supported, use the documented syntax to save the results for later analysis.

5. Findings and Classification

The assessment should record only results actually returned by the tool. Since the scan has not been executed in this environment, the following is a template for entering your observed results, not a claim that these addresses or hosts were discovered.

Information type	Findings to record
Email addresses	Actual publicly discovered addresses

Subdomains	Actual discovered subdomains
Hostnames	Actual hostnames returned
IP addresses	Actual IP addresses returned
Public sources	Search engines or data sources queried

Categorize discovered email addresses according to their actual names, documented functions, and verified public context.

Likely role	Example naming pattern	Potential security concern
Support	support@domain	Fake customer support requests
Sales	sales@domain	Fraudulent quotations or invoices
Human Resources	careers@domain	Fake recruitment messages
Administration	admin@domain	Administrative impersonation
Technical teams	it@domain, security@domain	Fake technical alerts or password-reset requests

These are illustrative naming patterns, not verified Tesla email addresses. An address should not be assigned to a role solely because its name appears similar.

6. Reconnaissance Risk Analysis

The collected information could assist an attacker during the reconnaissance phase in the following ways:

a) Spear-phishing

Attackers may use publicly available employee names, job titles, and organizational details to create convincing emails that appear to come from HR, IT support, or management.

b) Credential harvesting

An attacker may create a fraudulent login page and send a deceptive email asking recipients to verify their accounts. If a victim enters credentials, the attacker could attempt to misuse them.

c) Impersonation attacks

Publicly known email formats and department names may help an attacker impersonate an employee, supplier, or support representative.

d) Subdomain and host discovery

Subdomain and hostname information can help defenders identify externally exposed assets. Attackers could also use it to identify potential entry points or investigate outdated services.

e) Targeted social engineering

Knowledge of employee roles can make fraudulent requests appear relevant to a recipient's daily responsibilities.

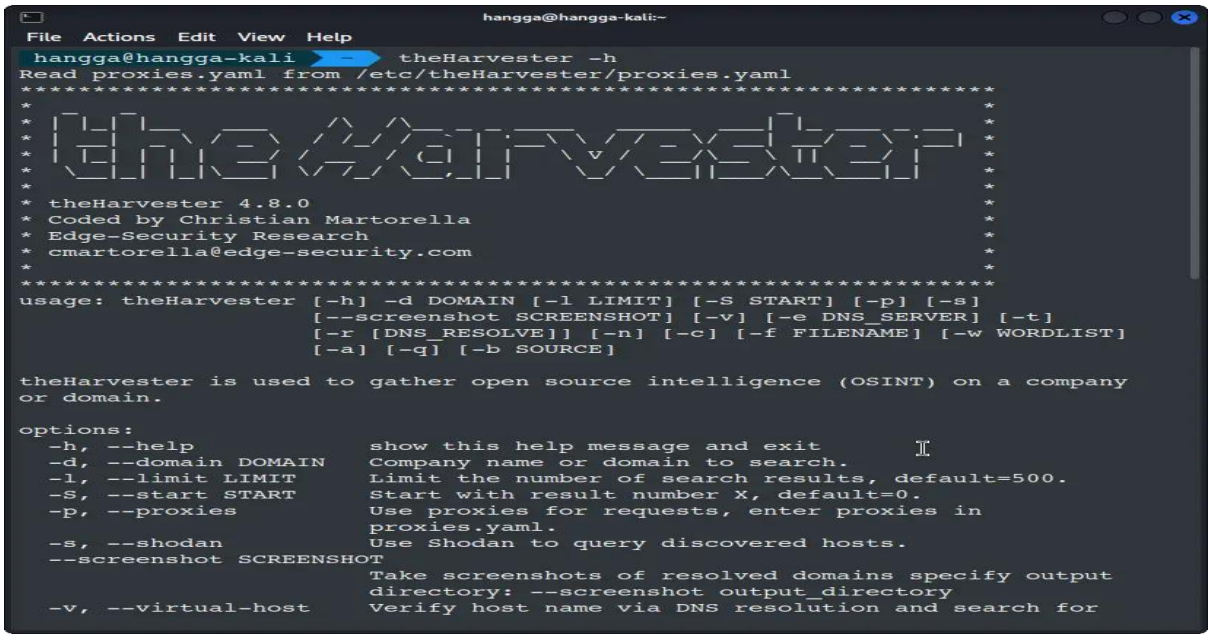
7. Countermeasures

1. Limit information exposure: Review public websites and documents for unnecessary employee contact details and internal infrastructure information.
2. Implement email authentication: Configure SPF, DKIM, and DMARC to reduce domain spoofing.
3. Enable multi-factor authentication (MFA): Require MFA for email, VPNs, administrative accounts, and other important services.
4. Conduct phishing awareness training: Teach employees to identify suspicious links, unexpected attachments, urgency, and unusual requests.
5. Monitor exposed assets: Regularly inventory public subdomains, hosts, and IP addresses, and remove unnecessary exposure.
6. Use secure email gateways: Filter malicious links, attachments, spoofed messages, and suspicious sender behavior.
7. Apply least privilege: Restrict access to sensitive information according to job responsibilities.

8. Establish incident reporting: Give employees a simple way to report suspicious emails and investigate them quickly.

8. Screenshot Evidence

Include your own screenshots from Kali Linux in the final report.



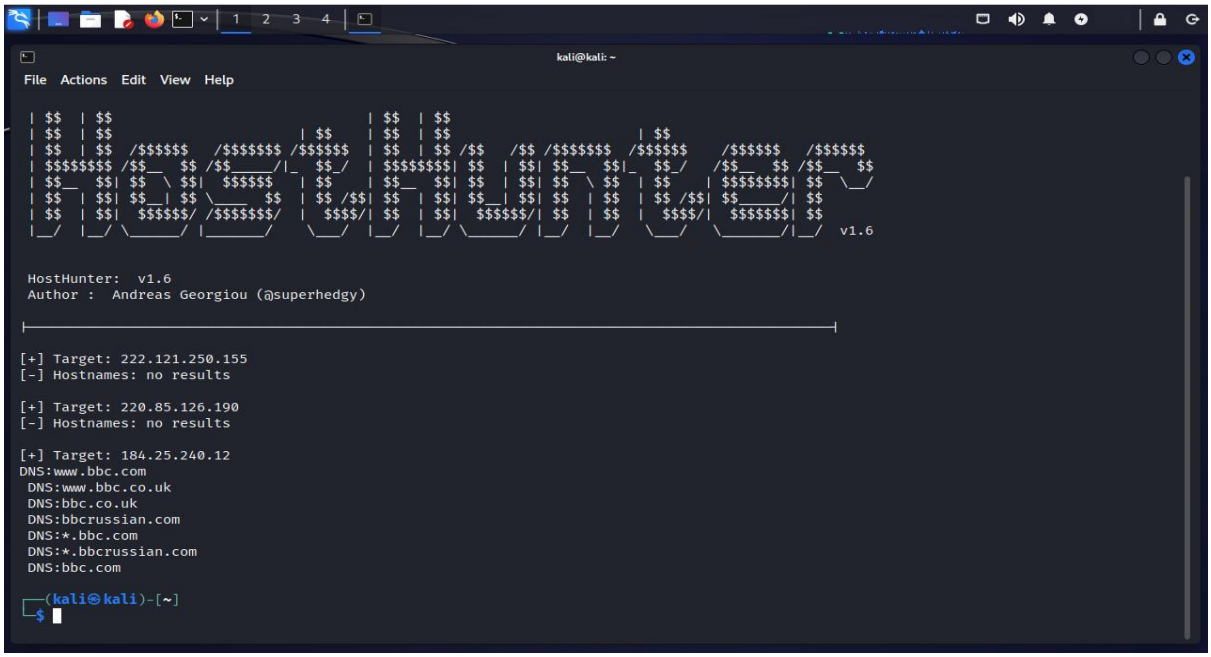
Screenshot 1: Installation and help

Show the installation or theHarvester -h command and its output.



Screenshot 2: OSINT scan

Show the executed command and the actual results returned by your selected source.



Screenshot 3: Findings

Show the observed email, hostname, subdomain, or IP results. Redact sensitive information where appropriate.

These images are visual references for the type of evidence to capture, not screenshots of a completed scan against Tesla.

9. Conclusion

TheHarvester helps security analysts understand an organization's public information exposure. Email addresses, subdomains, and hostnames can increase the effectiveness of phishing and impersonation attempts if not adequately protected. Regular OSINT assessments, email security, MFA, and employee awareness training help reduce these risks.

Question 2: Phishing Awareness Simulation Using GoPhish (20 Marks)

1. Aim

To conduct an authorized phishing awareness simulation using GoPhish and dummy employee accounts, monitor employee interactions, calculate campaign metrics, and recommend improvements to security awareness.

2. Tools Required

- GoPhish
- Kali Linux or another authorized lab machine
- Dummy employee email accounts
- An authorized SMTP server or lab mail server
- A web browser

3. Introduction

GoPhish is an open-source phishing simulation framework used to test how employees respond to simulated phishing emails. It enables security teams to create email templates, configure landing pages, launch campaigns, and analyze user interactions.

A controlled simulation should use dummy accounts or explicitly authorized participants. It should not collect real passwords or send deceptive messages to people outside the approved scope.

4. Procedure

Step 1: Start GoPhish

Launch GoPhish using the installation method appropriate for your lab. For a typical Linux installation:

cd gophish

./gophish

If your installation uses a different directory or service configuration, follow its documentation.

Open the administration interface at the configured local address, commonly:

https://127.0.0.1:3333

Use the credentials configured during installation. Keep the administration interface restricted to the lab machine or another trusted management network.

Step 2: Create a dummy recipient group

1. Open Users & Groups.
2. Create a group called Lab_Employees.
3. Add the dummy employee accounts supplied for the lab.
4. Verify that the addresses are test accounts and that sending is authorized.

Step 3: Create an email template

Open Email Templates, select New Template, and use the following educational example.

Subject: Security Awareness Exercise – Review a Sample Notification

Hello Employee,

You have been selected to participate in an internal security awareness exercise.

Please review the sample notification using the training link provided by your organization's security team:

Training link: {{.URL}}

This exercise is designed to help employees recognize unexpected messages and practice safe browsing habits.

If you are unsure about a message, verify it through an approved communication channel before taking action.

Regards,
Security Awareness Team

Note: Use GoPhish's supported template variables and campaign URL substitution. The linked landing page should be a training page that records only the permitted simulation event, not real credentials.

Step 4: Configure the sending profile

1. Open Sending Profiles.
2. Select New Profile.
3. Enter your lab SMTP server details.
4. Use an approved sender address and the test mail server's authentication settings.
5. Send a test email to a dummy account and verify delivery.

Step 5: Create the landing page

1. Open Landing Pages.
2. Create a simple training page explaining how to identify suspicious messages.
3. Display a message such as: “This was an authorized phishing awareness exercise. Check the sender, inspect links, and report suspicious emails.”
4. Do not store passwords or collect sensitive personal information.

Step 6: Launch the campaign

1. Open Campaigns and select New Campaign.
2. Choose the email template and sending profile.
3. Select the dummy employee group.
4. Configure the training landing page and the approved test URL.
5. Give the campaign a name such as Phishing_Awareness_Lab.
6. Launch it and monitor the campaign dashboard.

Step 7: Monitor campaign results

GoPhish records campaign events such as email sending, opening, link clicking, and submitted data, depending on the configuration and tracking settings.

Record the results from the campaign dashboard. Do not invent actual results or treat a missing tracking event as proof that a user did not interact with the message.

5. Calculating Campaign Metrics

Use the following formulas:

\[\text{Delivery Rate}= \frac{\text{Emails Delivered}}{\text{Emails Sent}}\times100 \]

\[\text{Open Rate}= \frac{\text{Unique Opens}}{\text{Emails Delivered}}\times100 \]

\[\text{Click Rate}= \frac{\text{Unique Clicks}}{\text{Emails Delivered}}\times100 \]

Open rates can be unreliable because some email clients block tracking pixels while others load them automatically. Click rates may also be affected by automated security scanners.

6. Sample Campaign Report

The following figures are illustrative only. Replace them with your actual GoPhish dashboard results.

Metric	Sample result
Emails sent	50
Emails delivered	45

Delivery rate	90%
Unique opens	30
Open rate	66.67%
Unique clicks	12
Click rate	26.67%

Calculations:

- Delivery rate = \(45/50 \times 100 = 90\%\)
- Open rate = \(30/45 \times 100 = 66.67\%\)
- Click rate = \(12/45 \times 100 = 26.67\%\)

Illustrative campaign metrics

Delivery rate

90%

Open rate

66.67%

Click rate

26.67%

Example visualization only; these are not observed campaign results.

7. Analysis and Recommendations

A high click rate may indicate that recipients need additional practice recognizing suspicious links. A low delivery rate may indicate SMTP, filtering, or address configuration problems rather than employee behavior.

Recommended improvements:

1. Conduct regular phishing awareness training.
2. Teach employees to verify sender addresses and URLs before clicking.

3. Enable MFA and discourage password reuse.
4. Deploy email authentication using SPF, DKIM, and DMARC.
5. Establish a clear process for reporting suspicious messages.
6. Use follow-up training for employees who interact with simulated phishing messages.
7. Repeat simulations periodically and compare results over time.
8. Track positive behavior, such as reporting a simulated phishing email, alongside clicks and opens.

8. Screenshots to Include

- GoPhish dashboard showing campaign status.
- Users & Groups page showing dummy recipients.
- Email template configuration.
- Sending profile configuration with sensitive settings hidden.
- Campaign results page showing sent, delivered, opened, and clicked events.
- Final report with calculated rates.

9. Conclusion

GoPhish helps organizations measure and improve employee awareness of phishing threats. Campaign metrics identify areas for improvement, while repeated training, MFA, secure email configurations, and incident-reporting procedures help reduce the risk of successful phishing attacks.

Question 3: Nmap Aggressive Scan and Social Engineering Risk Analysis (10 Marks)

1. Aim

To perform an aggressive scan of scanme.nmap.org using Nmap, identify open ports, operating system information, and service versions, and analyze how this information could support social engineering attacks against an IT support team.

2. Tools Required

- Kali Linux
- Nmap
- Terminal
- Internet connection

3. Introduction

Nmap (Network Mapper) is a network scanning tool used to discover hosts, identify open ports, detect running services, and assess network exposure.

The -A option enables several advanced detection features, including OS detection, service/version detection, default NSE script scanning, and traceroute. Because these features generate additional traffic, aggressive scans should be used only on authorized targets.

4. Commands Executed

Step 1: Check Nmap installation

nmap --version

Step 2: Perform the aggressive scan

nmap -A scanme.nmap.org

Run this against the designated public Nmap test host, within its permitted use and scanning scope.

Step 3: Save the scan report

nmap -A -oN nmap_report.txt scanme.nmap.org

This saves the normal-format output to nmap_report.txt.

Step 4: Review the results

cat nmap_report.txt

Review the output for:

- Host status
- Open TCP ports
- Service names and versions
- Operating system detection results
- Relevant script output
- Traceroute information, if available

5. Findings

Enter the results observed in your own terminal. The table below is a reporting template, not a claim that a scan has been performed here.

Scan component	Information to record
Target	scanme.nmap.org
Host status	Up or down
Open ports	Actual ports reported by Nmap
Services	Actual service names
Versions	Detected versions, if available
Operating system	Detected OS or inconclusive
NSE results	Relevant script findings
Traceroute	Hops shown, if available

Nmap's OS and version identification may be inconclusive, and results can change over time.

6. Social Engineering Attack Risk Analysis

An attacker could use publicly observable technical information to make fraudulent communications more believable.

Step 1: Reconnaissance

The attacker reviews public scan results and learns which services and technologies are exposed.

Step 2: Constructing a believable pretext

The attacker may use the general technical context to pose as a vendor, security auditor, or IT support employee. For example, the attacker could claim to be following up on a supposed server maintenance issue.

Step 3: Targeting IT support

A deceptive request might ask the IT team to verify a system, disclose internal procedures, or approve an unexpected access request. Technical terminology can make such a request appear credible.

Step 4: Attempted credential theft or unauthorized access

If the recipient trusts the request, they might be persuaded to visit a fraudulent login page, disclose sensitive information, or approve an unauthorized action.

Step 5: Potential consequences

Successful social engineering could lead to account compromise, data exposure, unauthorized access, service disruption, or further attacks against internal systems.

These are possible attack scenarios, not evidence that the scanned host is vulnerable or that its IT support team has been compromised.

7. Defensive Recommendations

1. Train IT support personnel: Conduct regular exercises focused on impersonation, fake vendor requests, and fraudulent security alerts.
2. Verify identities independently: Confirm unexpected requests through established contact details and approved communication channels.
3. Enforce MFA: Require multi-factor authentication for administrative and remote-access accounts.
4. Restrict exposed services: Close unnecessary ports and limit access to management interfaces.
5. Keep software updated: Apply security patches to operating systems and network services.
6. Monitor network activity: Use firewalls, IDS/IPS, and centralized logging to detect suspicious connections and scanning activity.
7. Use least privilege: Ensure support staff and service accounts have only the permissions they need.
8. Protect credentials: Never request passwords through email, and use approved identity-verification and password-reset procedures.

9. Reduce unnecessary disclosures: Avoid publishing detailed internal infrastructure and software-version information without a business need.

8. Screenshot Evidence

Include these screenshots in your assignment:

- Screenshot 1: nmap --version
- Screenshot 2: nmap -A scanme.nmap.org
- Screenshot 3: Open ports and service/version results
- Screenshot 4: Saved output displayed using cat nmap_report.txt

9. Conclusion

Nmap aggressive scanning helps security analysts identify exposed network services and gather technical information about a target. Although the information can support reconnaissance and social engineering, the risk can be reduced through service hardening, strong authentication, identity verification, network monitoring, and employee awareness training.